Ironbridge National Bank – Security Awareness and Training Program

Organization: Ironbridge National Bank
Program Owner: Governance, Risk, and Compliance (GRC) / Information Security
Scope: All employees, contractors, IT administrators, and management
Compliance Alignment: PCI DSS Requirement 12.6
Program Status: Proposed for Implementation

---

1. Program Purpose, Audience, and Goals

Purpose

Ironbridge National Bank's Security Awareness and Training Program is designed to reduce cybersecurity risks caused by human error, social engineering, improper handling of sensitive information, and misuse of authorized access.

The program complements the bank's existing security infrastructure, including Active Directory (ironbridge.local), role-based access controls, network segmentation, encrypted communications, endpoint monitoring, and incident response procedures.

Target Audience

Department / Role	Training Focus
All Employees	Phishing, social engineering, password security, incident reporting
Branch Operations	Customer impersonation, account fraud, customer information protection
Lending	Sensitive loan documentation, identity verification, secure document sharing
Finance	Business email compromise, fraudulent payments, deepfake impersonation
Compliance / GRC	PCI DSS, data handling, incident documentation

IT Administrators	Privileged access, account security, secure configuration, insider threats
Management	Fraud authorization, incident escalation, security accountability

Program Goals

1. Improve employees' ability to recognize phishing and social engineering attacks.
2. Reduce interactions with malicious links and attachments.
3. Increase the percentage of suspicious messages reported to Information Security.
4. Prevent unauthorized payments through mandatory independent verification.
5. Reduce accidental exposure of customer and transaction records.
6. Reinforce least-privilege access and responsible use of banking systems.
7. Encourage employees to question unusual requests without fear of penalty.

---

2. Core Security Awareness Training Topics

The following topics will be included in the bank's security awareness program.

Training Topic	Threat Description	Expected Employee Behavior
Phishing	Fraudulent emails attempt to steal credentials or deliver malware	Identify suspicious messages, avoid unexpected links, report attempts
Pretexting	Attackers impersonate trusted individuals or create false situations	Verify identities through trusted communication channels
Baiting	Attackers use enticing downloads, offers, or unknown USB devices	Avoid unauthorized downloads and removable media
Tailgating	Unauthorized individuals follow employees into restricted areas	Follow physical access procedures and report suspicious entry
Deepfake Fraud	AI-generated voices or videos impersonate executives or employees	Independently verify sensitive requests

Business Email Compromise (BEC)	Attackers impersonate executives or vendors to request fraudulent payments	Follow established payment verification procedures
Customer Data Protection	Sensitive records are improperly accessed, shared, or exposed	Access only authorized information and use approved systems
Insider Threats	Employees or contractors intentionally or accidentally misuse access	Follow least privilege and report suspicious activity

Mandatory Verify-Before-You-Act Rule

Ironbridge National Bank will establish a mandatory verification procedure for sensitive financial transactions and unusual requests.

Employees must:

- Independently verify payment requests through a previously established contact method.
- Never rely exclusively on an email address, phone number, voice, or video.
- Require dual authorization for high-value or sensitive transactions according to bank policy.
- Escalate unusual urgency, secrecy, payment-detail changes, or requests to bypass normal procedures.
- Preserve suspicious communications for Information Security review.

Example: A Finance employee receives an urgent video message appearing to come from a senior executive requesting a wire transfer. Even if the voice and appearance seem authentic, the employee must independently verify the request through an approved communication channel before processing the transaction.

---

3. Training Delivery and Frequency

Training will be delivered through onboarding, annual refresher courses, phishing simulations, role-specific exercises, and recurring security awareness communications.

Training Schedule

Training Activity	Frequency	Target Audience	Delivery Method

Initial Security Awareness Training	Within 30 days of onboarding	New employees	Instructor-led or online module
Annual Security Awareness Refresher	Annually	All employees	Online training and assessment
Phishing Simulations	Quarterly	All employees	Authorized simulated emails
Social Engineering and Fraud Training	Semiannually	Finance, Branch Operations, Lending	Scenario-based exercises
Privileged Access and Insider Threat Training	Annually	IT Administrators	Technical training
Security Awareness Reminders	Monthly	All employees	Email bulletins, posters, briefings
Incident Reporting Tabletop Exercise	Annually	Selected departments and security personnel	Facilitated exercise

Training Completion Requirements

- All employees must complete assigned security awareness training.
- Employees must achieve a minimum assessment score of 80%.
- Employees who do not meet the requirement will receive additional training and reassessment.
- GRC and Human Resources will maintain completion records.
- Department managers will follow up on overdue training.

---

4. Phishing Simulation Plan

Objective

Phishing simulations will evaluate employees' ability to identify suspicious messages, avoid unsafe interactions, and report potential threats.

Simulations will be authorized, harmless, and conducted through an approved training platform. They will not collect real employee credentials or introduce malicious software.

Simulation Procedure

Phase	Action	Responsible Team
1. Planning	Select the scenario, target audience, and measurement criteria	GRC / Information Security
2. Approval	Obtain management authorization and establish exercise boundaries	Management / Information Security
3. Execution	Deliver simulated phishing messages	Information Security
4. Monitoring	Record employee interactions and reports	Information Security
5. Analysis	Calculate click rates, report rates, and repeat interactions	GRC
6. Reinforcement	Provide educational feedback and targeted retraining	GRC / Department Managers
7. Improvement	Compare results with previous exercises and update training	GRC / Information Security

Example Phishing Simulation Scenarios

Scenario	Description	Expected Employee Response
IT Password Expiration	Email claims an employee must immediately verify account credentials	Avoid the link and report the message
Executive Wire Transfer	Message impersonates an executive requesting an urgent transfer	Independently verify and follow payment authorization
Vendor Payment Change	Email requests payment to a new bank account	Confirm changes through an established vendor contact
Shared Document Notification	Unexpected message requests access to a customer document	Verify the sender and report suspicious links
Deepfake Executive Request	Controlled tabletop scenario involving AI-generated executive impersonation	Refuse to bypass established authorization procedures

Handling Simulation Results

Simulation results will be used for employee education and program improvement rather than public embarrassment or automatic disciplinary action.

Employees who repeatedly interact with suspicious simulations will receive additional training focused on the behaviors involved.

Individual results will be restricted to authorized personnel. Management will primarily receive aggregate performance reports.

---

5. Security Awareness Metrics and Performance Measurement

Ironbridge National Bank will evaluate the effectiveness of its training program using measurable security awareness indicators.

Key Performance Indicators (KPIs)

Metric	Calculation	Proposed Target
Phishing Click Rate	Employees who clicked ÷ successfully delivered simulation emails × 100	Below 5%
Phishing Report Rate	Employees who reported ÷ successfully delivered simulation emails × 100	Above 80%
Repeat-Offender Rate	Employees with unsafe interactions in consecutive exercises ÷ participating employees × 100	Decreasing quarterly
Training Completion Rate	Employees completing training ÷ assigned employees × 100	100%
Assessment Pass Rate	Employees passing assessment ÷ employees assessed × 100	Above 90%
Payment Verification Compliance	Compliant reviewed transactions ÷ transactions reviewed × 100	100%

Quarterly Performance Tracking

Metric	Q1 Baseline	Q2	Q3	Q4
Phishing Click Rate	To be measured	TBD	TBD	TBD

Phishing Report Rate	To be measured	TBD	TBD	TBD
Repeat-Offender Rate	To be measured	TBD	TBD	TBD
Training Completion Rate	To be measured	TBD	TBD	TBD

Performance Review

GRC will review training metrics quarterly.

The first quarter will establish baseline results. Subsequent quarters will be compared against these results to identify improvements and recurring weaknesses.

If employees consistently recognize basic phishing emails but struggle with fraudulent payment requests, additional training will focus on business email compromise and deepfake-enabled fraud.

Aggregate performance metrics may be incorporated into the bank's Power BI security dashboard for management reporting.

All thresholds are proposed targets and will be evaluated after baseline measurements become available.

---

6. Reinforcement and Security Culture

Ironbridge National Bank will establish a security culture that encourages employees to question unusual requests, verify identities, and promptly report potential threats.

Pause, Verify, Report

1. PAUSE

Employees should avoid acting immediately on unexpected, urgent, or unusual requests.

2. VERIFY

Employees should independently verify identities and instructions through trusted communication channels.

3. REPORT

Employees should report suspicious activity to the designated IT or Information Security team.

Reinforcement Strategies

Strategy	Implementation
Positive Reporting Culture	Encourage employees to question suspicious requests without fear of penalty
Non-Punitive Phishing Education	Provide constructive feedback and additional training after simulation mistakes
Monthly Security Reminders	Distribute communications about current threats and prevention techniques
Management Participation	Require executives and managers to follow the same verification procedures
Employee Recognition	Recognize departments demonstrating improved reporting and training participation
Lessons Learned	Incorporate findings from security incidents into future training

The objective is to make secure behavior part of normal banking operations rather than an activity performed only during annual training.

---

7. Integration With Security Policies and Incident Response

The Security Awareness and Training Program will reinforce the bank's established security policies and incident response procedures.

Security Policy Integration

Security Policy	Awareness Training Connection
Acceptable Use Policy	Approved use of bank systems, email, software, and internet resources
Access Control Policy	Least privilege, individual accounts, and authorized access

Password and Authentication Policy	Credential protection, MFA, and suspicious authentication requests
Data Classification and Handling Policy	Proper storage, sharing, and protection of customer information
Payment Authorization Policy	Independent verification and approved transaction authorization
Incident Response Policy	Employee reporting responsibilities and escalation procedures
Physical Security Policy	Visitor verification and prevention of unauthorized access

Incident Reporting Procedure

1. An employee identifies suspicious activity.
2. The employee reports the concern to IT or Information Security.
3. The Security team investigates and classifies the event.
4. The appropriate incident response playbook is activated when necessary.
5. The incident is documented, and relevant lessons are incorporated into future training.

Employee reports may also be correlated with authentication, account-management, and system events in the bank's Splunk index, idx_team4, once centralized monitoring is operational.

---

8. Integration With Ironbridge Incident Response Playbooks

The Security Awareness and Training Program supports the bank's existing incident response playbooks by reducing the likelihood of successful attacks and improving employee reporting.

Playbook Alignment

Incident Response Playbook	Relevant Training	Risk Reduction
Playbook 1: Phishing and Business Email Compromise	Phishing recognition, sender verification, payment authorization	Reduces unsafe email interactions and fraudulent payment approvals

Playbook 7: AI Deepfake-Enabled Fraudulent Transaction Request	Deepfake awareness, independent verification, dual authorization	Prevents reliance on apparently authentic voices or videos
Playbook 8: Insider Threat	Least privilege, acceptable use, data handling, reporting	Reduces accidental misuse and encourages reporting
Playbook 9: Data Exfiltration	Customer data protection and secure file sharing	Reduces accidental disclosure and improves recognition of suspicious requests
Playbook 6: Brute Force and Credential Stuffing	Password security, MFA, suspicious login reporting	Reduces credential exposure and improves detection of account compromise

Example: Preventing a Deepfake-Enabled Fraudulent Transfer

Scenario: A Finance employee receives an urgent video message appearing to come from a senior executive requesting an immediate wire transfer.

Without Awareness Training: The employee may trust the executive's apparent identity and process the request without independent verification.

With Awareness Training: The employee recognizes the possibility of AI-generated impersonation, independently contacts the executive through an approved channel, follows the bank's transaction authorization procedures, and reports the suspicious request.

Expected Outcome: The fraudulent transaction is prevented before funds are transferred.

This scenario demonstrates how employee awareness supports Playbook 7 and complements the bank's technical security controls.

---

9. PCI DSS Requirement 12.6 Alignment

The Security Awareness and Training Program is designed to support PCI DSS Requirement 12.6, which addresses security awareness education.

PCI DSS Compliance Mapping

PCI DSS Requirement	Program Control	Evidence

12.6.1	Establish a formal security awareness program	Approved program documentation
12.6.2	Review and update the program periodically	Annual review records and revision history
12.6.3	Provide training upon hire and at least annually	Training completion records
12.6.3.1	Include phishing and social engineering awareness	Training materials and simulation reports
12.6.3.2	Include acceptable use of end-user technologies	Training content and employee acknowledgments

Compliance Evidence

GRC will maintain the following documentation:

- Approved Security Awareness and Training Program.
- Annual training schedule.
- Employee completion and attendance records.
- Training materials and presentations.
- Knowledge assessment results.
- Phishing simulation reports.
- Corrective training documentation.
- Annual program review and management approval.

Training records must be stored securely and retained according to the bank's approved retention policy.

The existence of a written program alone does not establish full compliance. Actual training delivery, employee acknowledgment, periodic review, and supporting evidence must also be demonstrated.

---

10. Program Ownership and Continuous Improvement

Roles and Responsibilities

Responsible Party	Responsibilities

GRC / Compliance	Own the program, track metrics, maintain compliance evidence, review PCI DSS alignment
Information Security / IT	Develop technical content, administer simulations, investigate reported threats
Human Resources	Incorporate training into onboarding and track employee participation
Department Managers	Ensure employees complete training and follow verification procedures
Executive Management	Approve program requirements, allocate resources, review effectiveness
Employees	Complete training, follow security policies, and report suspicious activity

Annual Program Review

GRC and Information Security will review the training program at least annually and following significant security incidents.

The review will evaluate:

- Employee training completion rates.
- Phishing simulation results.
- Repeat interactions with suspicious messages.
- Incident reporting trends.
- Effectiveness of role-specific training.
- Emerging cybersecurity threats.

Improvement actions will be assigned to responsible owners and tracked to completion.

---

11. Program Conclusion

Ironbridge National Bank's Security Awareness and Training Program establishes a formal and measurable approach to reducing human-related cybersecurity risks.

The program addresses phishing, pretexting, baiting, tailgating, business email compromise, deepfake-enabled fraud, insider threats, and improper handling of customer information.

By combining role-specific training, phishing simulations, measurable performance indicators, and a mandatory verify-before-you-act procedure, the bank can strengthen its security culture and reduce the likelihood of successful social engineering attacks.

The program directly supports the bank's incident response playbooks and is designed to align with PCI DSS Requirement 12.6.

Implementation Status: The program has been designed. Actual training delivery, employee completion records, simulation results, and management approval must be documented as the program is implemented.